

# MODELO DE AMENAZAS

## EcoRoute — Identificación de Vectores de Ataque Potenciales

### 1. INTRODUCCIÓN

#### 1.1 Propósito

Este documento identifica y analiza las amenazas de seguridad potenciales del sistema EcoRoute usando la metodología **STRIDE** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege). El objetivo es anticipar vectores de ataque antes de que el sistema sea desplegado, definir controles de mitigación y establecer los límites de confianza del sistema.

#### 1.2 Contexto de Seguridad de EcoRoute

EcoRoute es un sistema de investigación científica que opera localmente en la máquina del investigador. No es un sistema web público ni un sistema embebido en infraestructura vial real. Sin embargo, presenta superficies de ataque relevantes que deben ser consideradas:

| Superficie de ataque        | Descripción                                                                        |
|-----------------------------|------------------------------------------------------------------------------------|
| Archivos de configuración   | config.yaml contiene parámetros críticos que afectan el comportamiento del agente  |
| Checkpoints del modelo      | Archivos .pth serializados con pickle que contienen los pesos del agente entrenado |
| Conexión TraCI local        | Socket TCP localhost entre Python y el proceso SUMO                                |
| Archivos de simulación SUMO | Archivos XML que definen la intersección y los flujos vehiculares                  |
| Resultados y métricas       | Archivos CSV y gráficas que contienen los resultados del experimento               |
| Dependencias de terceros    | PyTorch, SUMO, NumPy y otras bibliotecas con posibles CVEs                         |

#### 1.3 Metodología Utilizada

| Metodología              | Descripción                                                                                 |
|--------------------------|---------------------------------------------------------------------------------------------|
| <b>STRIDE</b>            | Framework de Microsoft para clasificar amenazas en 6 categorías                             |
| <b>Árbol de amenazas</b> | Descomposición jerárquica de ataques por objetivo                                           |
| <b>DREAD</b>             | Scoring de riesgo: Damage, Reproducibility, Exploitability, Affected users, Discoverability |

#### 1.4 Alcance del Modelo

**Dentro del alcance:**

- Sistema EcoRoute ejecutándose localmente en hardware del investigador
- Archivos de configuración, checkpoints y resultados en disco
- Conexión TraCI entre Python y SUMO
- Dependencias de software del proyecto

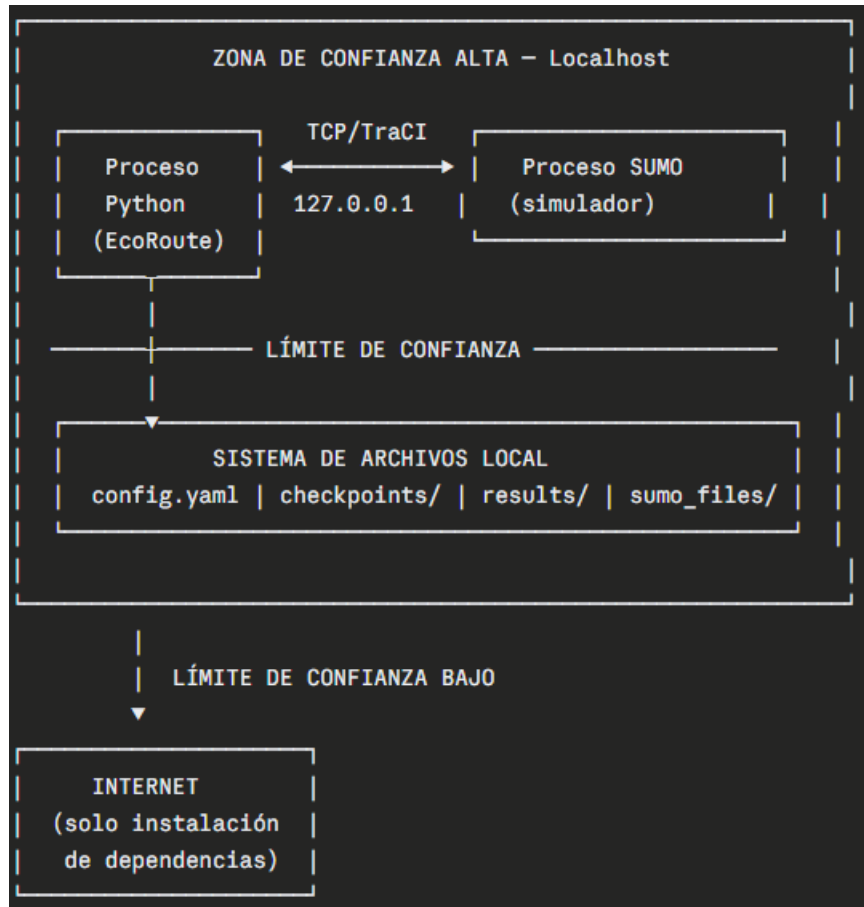
**Fuera del alcance:**

- Infraestructura vial física real (EcoRoute no controla semáforos reales)
- Despliegue en servidores remotos o nube
- Acceso multiusuario simultáneo

**2. DIAGRAMA DE FLUJO DE DATOS Y LÍMITES DE CONFIANZA****2.1 Actores y Componentes**

| Actor / Componente        | Nivel de confianza | Descripción                                      |
|---------------------------|--------------------|--------------------------------------------------|
| Investigador              | Alto               | Usuario legítimo del sistema con acceso completo |
| Proceso Python (EcoRoute) | Alto               | Proceso principal del sistema                    |
| Proceso SUMO              | Alto               | Simulador controlado localmente                  |
| Sistema de archivos local | Medio              | Almacena configuración, checkpoints y resultados |
| Dependencias pip/conda    | Medio              | Bibliotecas de terceros instaladas               |
| Red local (localhost)     | Alto               | Solo conexión TraCI en loopback                  |
| Internet                  | Bajo               | Solo para instalación de dependencias            |

**2.2 Límites de Confianza**



### 3. CATÁLOGO DE AMENAZAS — METODOLOGÍA STRIDE

#### 3.1 S — Spoofing (Suplantación de Identidad)

| ID       | Amenaza                                               | Vector                                                                                                                                                                                              | Componente afectado     |
|----------|-------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| THR-S-01 | Sustitución del archivo config.yaml por uno malicioso | Un actor malicioso con acceso al sistema de archivos reemplaza config.yaml con parámetros que hacen que el agente aprenda una política deliberadamente ineficiente o que consuma recursos excesivos | config/config_loader.py |
| THR-S-02 | Sustitución de un checkpoint .pth por uno manipulado  | Un archivo .pth malicioso inyectado en results/checkpoints/ que contiene código arbitrario ejecutable al deserializar con pickle                                                                    | agent/dqn_agent.py      |
| THR-S-03 | Sustitución de archivos de                            | Reemplazo de intersection.net.xml o routes.rou.xml por archivos que modelen una intersección diferente a la                                                                                         | sumo_files/             |

|  |                 |                                                     |  |
|--|-----------------|-----------------------------------------------------|--|
|  | simulación SUMO | documentada, invalidando los resultados científicos |  |
|--|-----------------|-----------------------------------------------------|--|

**Scoring DREAD — THR-S-02 (más crítica):**

| Dimensión DREAD    | Puntuación (1-10) | Justificación                                                 |
|--------------------|-------------------|---------------------------------------------------------------|
| Damage             | 9                 | Ejecución de código arbitrario en la máquina del investigador |
| Reproducibility    | 7                 | Reproducible si se tiene acceso al sistema de archivos        |
| Exploitability     | 6                 | Requiere acceso físico o remoto al sistema de archivos        |
| Affected users     | 3                 | Solo el investigador local                                    |
| Discoverability    | 5                 | Conocido por actores con conocimiento de PyTorch/pickle       |
| <b>DREAD Total</b> | <b>6.0</b>        | <b>Riesgo Medio-Alto</b>                                      |

**Controles de mitigación:**

| Control                                   | Descripción                                                                                                 | Implementación                            |
|-------------------------------------------|-------------------------------------------------------------------------------------------------------------|-------------------------------------------|
| Verificación de integridad de checkpoints | Calcular y verificar hash SHA-256 del archivo .pth antes de cargarlo                                        | Implementar en DQNAgent.load_checkpoint() |
| Permisos de sistema de archivos           | Restringir permisos de escritura en results/checkpoints/ al usuario propietario                             | chmod 700 results/checkpoints/            |
| Validación de config.yaml                 | Validar esquema y tipos antes de usar cualquier parámetro                                                   | Implementado en ConfigLoader.validate()   |
| Firma digital de archivos SUMO            | Calcular hash SHA-256 de los archivos XML de simulación al crearlos y verificarlo antes de cada experimento | Script de verificación en sumo_files/     |

**3.2 T — Tampering (Manipulación de Datos)**

| ID | Amenaza | Vector | Componente afectado |
|----|---------|--------|---------------------|
|----|---------|--------|---------------------|

|          |                                                     |                                                                                                                                                                 |                         |
|----------|-----------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|
| THR-T-01 | Manipulación de métricas CSV durante el experimento | Modificación de los archivos CSV en results/metrics/ durante el entrenamiento para alterar los resultados reportados                                            | evaluation/logger.py    |
| THR-T-02 | Inyección de parámetros maliciosos en config.yaml   | Modificación de pesos de recompensa (alpha, beta, gamma) para sesgar el aprendizaje del agente hacia una política que maximice emisiones en lugar de reducirlas | config/config.yaml      |
| THR-T-03 | Manipulación del proceso SUMO vía TraCI             | Intercepción y modificación de mensajes en la conexión TraCI para alterar los datos de tráfico que recibe el agente                                             | environment/sumo_env.py |
| THR-T-04 | Modificación de dependencias instaladas             | Reemplazo de un paquete pip instalado (PyTorch, NumPy) por una versión modificada que altera el comportamiento matemático del entrenamiento                     | environment.yml, pip    |

#### Scoring DREAD — THR-T-04 (más crítica):

| Dimensión DREAD    | Puntuación (1-10) | Justificación                                                          |
|--------------------|-------------------|------------------------------------------------------------------------|
| Damage             | 8                 | Comportamiento del agente completamente alterado sin evidencia visible |
| Reproducibility    | 5                 | Requiere acceso al gestor de paquetes o repositorio pip                |
| Exploitability     | 4                 | Requiere comprometer PyPI o el entorno conda local                     |
| Affected users     | 3                 | Solo el investigador local                                             |
| Discoverability    | 6                 | Conocido vector de ataque supply chain                                 |
| <b>DREAD Total</b> | <b>5.2</b>        | <b>Riesgo Medio</b>                                                    |

#### Controles de mitigación:

| Control                              | Descripción                                             | Implementación                  |
|--------------------------------------|---------------------------------------------------------|---------------------------------|
| Versiones fijadas en environment.yml | Fijar versión exacta de todas las dependencias críticas | Implementado en environment.yml |

|                                 |                                                                                         |                                         |
|---------------------------------|-----------------------------------------------------------------------------------------|-----------------------------------------|
| environment_locked.yml          | Fijar también dependencias transitivas con hashes                                       | conda env export --no-builds            |
| Verificación de hashes pip      | Usar pip install con --require-hashes para verificar integridad                         | Agregar hashes en requirements.txt      |
| Escritura atómica de CSV        | Escribir métricas en archivo temporal y renombrar atómicamente al finalizar el episodio | Implementar en Logger.log_episode()     |
| TraCI sobre loopback únicamente | Configurar SUMO para aceptar conexiones TraCI solo desde 127.0.0.1                      | sumo --remote-port [port] --no-step-log |

### 3.3 R — Repudiation (Repudio)

| ID       | Amenaza                                                | Vector                                                                                                                                                                                               | Componente afectado |
|----------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|
| THR-R-01 | Falta de trazabilidad entre configuración y resultados | No hay registro automático de qué config.yaml se usó para generar cada checkpoint y cada CSV de métricas, permitiendo que los resultados sean disputados o atribuidos a una configuración incorrecta | Todos los módulos   |
| THR-R-02 | Ausencia de log inmutable de ejecución                 | Sin log de auditoría, no es posible verificar exactamente cuándo se ejecutó un experimento, qué semilla se usó y qué versión del código produjo los resultados                                       | training/trainer.py |

#### Controles de mitigación:

| Control                             | Descripción                                                                                            | Implementación                           |
|-------------------------------------|--------------------------------------------------------------------------------------------------------|------------------------------------------|
| Registro de metadatos en checkpoint | Incluir en cada .pth: hash de config.yaml, versión del código (git commit hash), semilla, fecha y hora | Implementar en Trainer.save_checkpoint() |
| Log estructurado de experimentos    | Crear results/experiments/index.json con registro inmutable de cada experimento ejecutado              | Implementar en Trainer.train()           |

|                                  |                                                                                        |                                                                    |
|----------------------------------|----------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| Hash de config en nombre del CSV | Incluir los primeros 8 caracteres del hash de config.yaml en el nombre del archivo CSV | Implementar en <code>Logger.export_csv()</code>                    |
| Git commit en metadatos          | Registrar automáticamente el hash del commit Git activo al inicio de cada experimento  | <code>subprocess.check_output(['git', 'rev-parse', 'HEAD'])</code> |

### 3.4 I — Information Disclosure (Divulgación de Información)

| ID       | Amenaza                                                  | Vector                                                                                                                                                        | Componente afectado    |
|----------|----------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|
| THR-I-01 | Exposición de rutas absolutas del sistema en logs        | Los mensajes de log o error pueden incluir rutas absolutas del sistema de archivos del investigador que revelan información sobre la estructura de la máquina | Todos los módulos      |
| THR-I-02 | Exposición de datos del experimento en repositorio Git   | Archivos de resultados, checkpoints o config.yaml con semillas específicas podrían ser subidos accidentalmente al repositorio público de Git                  | results/, checkpoints/ |
| THR-I-03 | Checkpoints .pth revelan arquitectura y pesos del modelo | Un archivo .pth compartido inadvertidamente expone la arquitectura completa de la red neuronal y los pesos aprendidos                                         | results/checkpoints/   |

#### Controles de mitigación:

| Control                           | Descripción                                                                                        | Implementación                                          |
|-----------------------------------|----------------------------------------------------------------------------------------------------|---------------------------------------------------------|
| .gitignore completo               | Excluir results/, htmlcov/, *.pth, *.csv de Git                                                    | Implementado en .gitignore                              |
| Rutas relativas en logs           | Usar rutas relativas en todos los mensajes de log                                                  | Implementar con <code>pathlib.Path.relative_to()</code> |
| Sanitización de mensajes de error | Eliminar rutas absolutas de mensajes de excepción antes de mostrarlos                              | Implementar en ConfigLoader y SumoEnv                   |
| Revisión pre-commit de archivos   | Hook pre-commit que verifica que no se agregan archivos de results/ o checkpoints/ al staging area | Implementar en .pre-commit-config.yaml                  |

### 3.5 D — Denial of Service (Denegación de Servicio)

| ID       | Amenaza                                                      | Vector                                                                                                                                           | Componente afectado                  |
|----------|--------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| THR-D-01 | Agotamiento de memoria por replay buffer sin límite efectivo | Un valor de <code>replay_buffer_capacity</code> extremadamente alto en <code>config.yaml</code> agota la RAM disponible durante el entrenamiento | <code>agent/replay_buffer.py</code>  |
| THR-D-02 | Bucle infinito por episodio sin límite de pasos              | Si <code>max_steps</code> no está configurado, un episodio puede ejecutarse indefinidamente si <code>done</code> nunca se vuelve True            | <code>environment/sumo_env.py</code> |
| THR-D-03 | Llenado del disco por métricas y gráficas sin control        | Experimentos largos sin rotación de archivos pueden llenar el disco disponible con CSV y gráficas                                                | <code>evaluation/logger.py</code>    |
| THR-D-04 | Proceso SUMO zombie por fallo en cierre de conexión TraCI    | Si EcoRoute termina abruptamente sin cerrar TraCI, el proceso SUMO queda corriendo indefinidamente consumiendo CPU y RAM                         | <code>environment/sumo_env.py</code> |

#### Controles de mitigación:

| Control                                                        | Descripción                                                                                                                        | Implementación                                                   |
|----------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------|
| Límite máximo de <code>replay_buffer_capacity</code>           | Definir en <code>ConfigLoader</code> un valor máximo absoluto de 100.000 transiciones y rechazar valores superiores                | Implementar en <code>ConfigLoader.validate()</code>              |
| <code>max_steps</code> obligatorio en <code>config.yaml</code> | Hacer obligatorio el parámetro <code>max_steps_per_episode</code> y usarlo en el loop de <code>step()</code>                       | Implementar en <code>SumoEnv</code> y <code>config schema</code> |
| Rotación de archivos de resultados                             | Implementar identificador de experimento único en cada nombre de archivo y alertar si <code>results/</code> supera 5 GB            | Implementar en <code>Logger</code>                               |
| Context manager para SUMO                                      | Implementar <code>SumoEnv</code> como context manager ( <b>enter/exit</b> ) que garantiza cierre de TraCI incluso ante excepciones | Implementar con <code>try/finally</code> en <code>SumoEnv</code> |



|                           |                                                                               |                                             |
|---------------------------|-------------------------------------------------------------------------------|---------------------------------------------|
| Monitoreo de uso de disco | Verificar espacio disponible en disco antes de iniciar cada experimento largo | Implementar en <code>Trainer.train()</code> |
|---------------------------|-------------------------------------------------------------------------------|---------------------------------------------|

### 3.6 E — Elevation of Privilege (Elevación de Privilegios)

| ID       | Amenaza                                                                 | Vector                                                                                                                                                                                 | Componente afectado                  |
|----------|-------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| THR-E-01 | Ejecución de código arbitrario via deserialización pickle de checkpoint | <code>torch.load()</code> de un archivo <code>.pth</code> malicioso puede ejecutar código arbitrario durante la deserialización, potencialmente con los privilegios del proceso Python | <code>agent/dqn_agent.py</code>      |
| THR-E-02 | Inyección de comandos en rutas de archivos de configuración             | Si <code>sumo_config_path</code> en <code>config.yaml</code> contiene caracteres especiales del shell, podría usarse para inyección de comandos en el subprocess que inicia SUMO       | <code>environment/sumo_env.py</code> |
| THR-E-03 | Dependencia comprometida con acceso a recursos del sistema              | Una dependencia de terceros comprometida (supply chain attack) podría acceder a archivos del sistema, variables de entorno o conexiones de red                                         | <code>environment.yml</code>         |

#### Controles de mitigación:

| Control                                                          | Descripción                                                                                                                  | Implementación                                                  |
|------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| Verificar hash antes de <code>torch.load()</code>                | Calcular SHA-256 del <code>.pth</code> y compararlo con el hash registrado en el index de experimentos antes de deserializar | Implementar en <code>DQNAgent.load_checkpoint()</code>          |
| Usar <code>weights_only=True</code> en <code>torch.load()</code> | PyTorch 2.0+ soporta carga segura de solo pesos sin deserialización pickle completa                                          | <code>torch.load(path, weights_only=True)</code>                |
| Validar rutas con <code>pathlib</code>                           | Usar <code>pathlib.Path</code> para validar y sanitizar todas las rutas de                                                   | Implementar en <code>SumoEnv</code> y <code>ConfigLoader</code> |

|                                     |                                                                                                 |                                                                   |
|-------------------------------------|-------------------------------------------------------------------------------------------------|-------------------------------------------------------------------|
|                                     | archivos antes de pasarlas a subprocess                                                         |                                                                   |
| Ejecutar SUMO sin shell=True        | Usar subprocess.Popen con lista de argumentos en lugar de string para evitar inyección de shell | sumo_process = subprocess.Popen([sumo_binary, '-c', config_path]) |
| Auditoría periódica de dependencias | Ejecutar pip-audit y safety semanalmente según el Plan de Parches                               | Proceso definido en Plan de Parches                               |

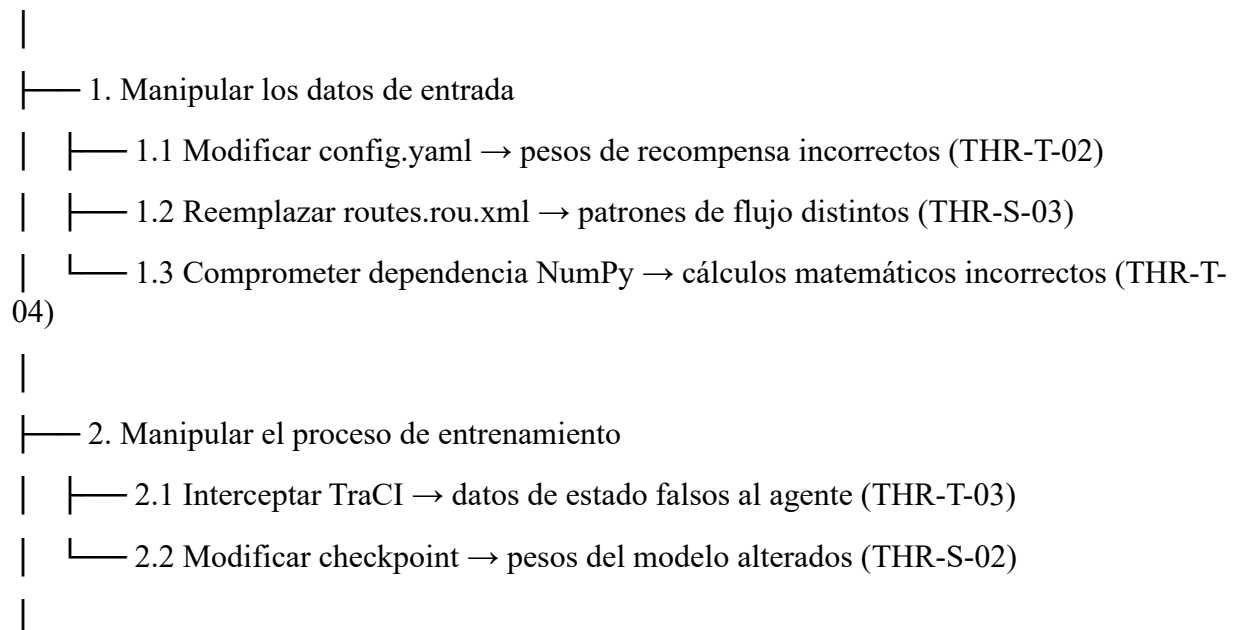
#### 4. RESUMEN DE AMENAZAS POR NIVEL DE RIESGO

| ID       | Amenaza                                           | Categoría STRIDE       | DREAD | Nivel de riesgo | Control principal                |
|----------|---------------------------------------------------|------------------------|-------|-----------------|----------------------------------|
| THR-S-02 | Checkpoint .pth malicioso con código arbitrario   | Spoofing               | 6.0   | Medio-Alto      | weights_only=True + hash SHA-256 |
| THR-T-04 | Dependencia pip comprometida (supply chain)       | Tampering              | 5.2   | Medio           | Hashes en requirements.txt       |
| THR-E-01 | Ejecución de código via pickle en torch.load()    | Elevation of Privilege | 5.8   | Medio-Alto      | weights_only=True                |
| THR-T-02 | Inyección de parámetros maliciosos en config.yaml | Tampering              | 4.8   | Medio           | Validación de esquema y tipos    |
| THR-D-04 | Proceso SUMO zombie por fallo en TraCI            | Denial of Service      | 4.5   | Medio           | Context manager con finally      |
| THR-S-01 | Sustitución de config.yaml                        | Spoofing               | 4.2   | Medio           | Permisos + validación            |
| THR-T-03 | Manipulación de mensajes TraCI                    | Tampering              | 3.8   | Bajo-Medio      | TraCI solo en loopback           |

|          |                                         |                        |     |            |                             |
|----------|-----------------------------------------|------------------------|-----|------------|-----------------------------|
| THR-D-01 | Agotamiento de RAM por replay buffer    | Denial of Service      | 3.5 | Bajo-Medio | Límite máximo en validación |
| THR-D-02 | Bucle infinito por episodio sin límite  | Denial of Service      | 3.2 | Bajo-Medio | max_steps obligatorio       |
| THR-R-01 | Falta de trazabilidad config-resultados | Repudiation            | 3.0 | Bajo       | Metadatos en checkpoint     |
| THR-I-02 | Resultados expuestos en repositorio Git | Information Disclosure | 2.8 | Bajo       | .gitignore completo         |
| THR-E-02 | Inyección en ruta de config SUMO        | Elevation of Privilege | 2.5 | Bajo       | pathlib + sin shell=True    |
| THR-D-03 | Llenado de disco por métricas           | Denial of Service      | 2.2 | Bajo       | Rotación de archivos        |
| THR-I-01 | Rutas absolutas en logs                 | Information Disclosure | 2.0 | Bajo       | Rutas relativas en logs     |
| THR-R-02 | Ausencia de log inmutable               | Repudiation            | 1.8 | Bajo       | index.json de experimentos  |

## 5. ÁRBOL DE AMENAZAS — OBJETIVO: COMPROMETER RESULTADOS CIENTÍFICOS

OBJETIVO: Invalidar o falsificar resultados del experimento EcoRoute



└─ 3. Manipular los datos de salida

└─ 3.1 Modificar CSV de métricas → resultados falsificados (THR-T-01)

└─ 3.2 Alterar metadatos de experimento → trazabilidad rota (THR-R-01)